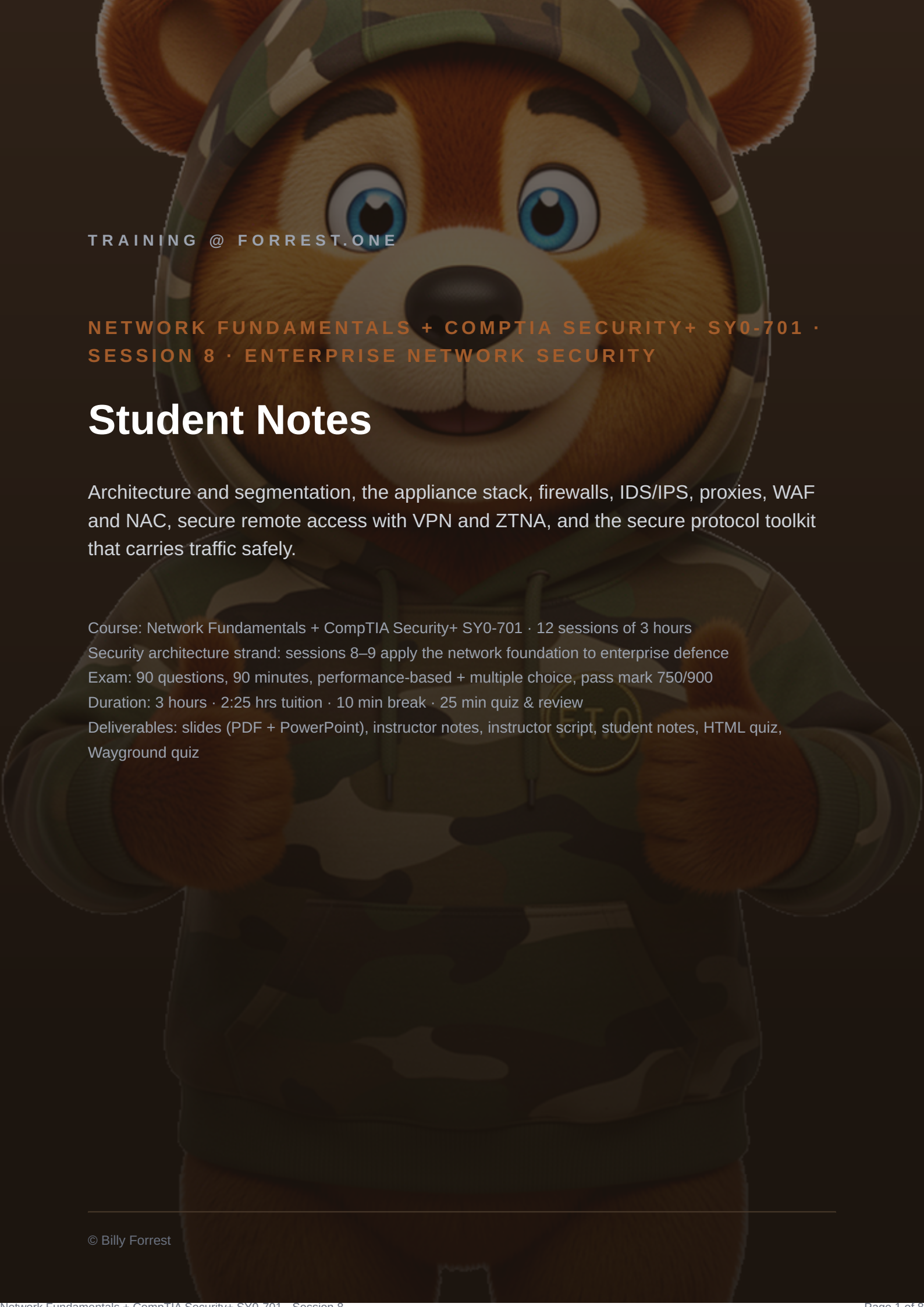




TRAINING @ FORREST.ONE

NETWORK FUNDAMENTALS + COMPTIA SECURITY+ SY0-701 ·
SESSION 8 · ENTERPRISE NETWORK SECURITY

Student Notes

Architecture and segmentation, the appliance stack, firewalls, IDS/IPS, proxies, WAF and NAC, secure remote access with VPN and ZTNA, and the secure protocol toolkit that carries traffic safely.

Course: Network Fundamentals + CompTIA Security+ SY0-701 · 12 sessions of 3 hours

Security architecture strand: sessions 8–9 apply the network foundation to enterprise defence

Exam: 90 questions, 90 minutes, performance-based + multiple choice, pass mark 750/900

Duration: 3 hours · 2:25 hrs tuition · 10 min break · 25 min quiz & review

Deliverables: slides (PDF + PowerPoint), instructor notes, instructor script, student notes, HTML quiz, Wayground quiz

Student Notes, Network Security Controls & Segmentation

Your revision guide for Session 8. The session follows six chapters: the physical and human layer, segmenting the network, guests and personal devices, hardening and admission control, keys and content control, and trust zones. Read these notes alongside the slides, then use the self-check questions and the session quiz to confirm you can place the right control in the right position, which is the scenario skill the exam rewards.

Key terms

Term	Definition
Physical controls	Rooms, locks, surveillance and visitor management that protect the hardware
Key lock	Cheap but pickable and duplicateable; the weakest access control
Combination lock	No key to lose, but the code is a shared secret
Electronic access control	Cards and fobs, which can be revoked instantly when lost
Biometrics	Hardest to share, costliest to run, and not revocable if copied
Access log	Record of who entered a secure space, and when
Honeypot	A decoy system built to attract attackers away from real targets
Low interaction honeypot	Simulates few services: simple, safe, shallow detail
High interaction honeypot	Runs a full operating system: rich detail, more risk
Honeynet	A network of decoys, which makes lateral movement visible
Entrapment	Inducing an offence; a decoy must observe and record, never solicit
Internal audit	Assurance run by your own team; deep system knowledge
External audit	Independent third party assessment, often required by a regulator
PCI DSS	Payment Card Industry Data Security Standard: protect cardholder data
GDPR	EU personal data rules: consent, access, correction and deletion
Data locality	Requirement that citizens' records stay within a country
VLAN	Virtual local area network: one switch split into logical networks

Term	Definition
Firewall zone	A boundary that defines what may cross between segments
Micro-segmentation	Policy applied per workload, not per rack or physical segment
Least connectivity	Allow only the connections that are actually necessary
IoT	Internet of things: cheap, rarely patched, often default credentials
Operational technology	Systems controlling physical processes, where availability outranks confidentiality
SCADA / ICS	Industrial control systems, legacy by design and often unpatchable
Purdue model	Layered industrial reference model, levels 0 to 4, plus an air gap
Air gap	Physical isolation from other networks, for near-zero intrusion risk
Guest VLAN	A separate segment giving guests internet access only
Captive portal	Web page presenting acceptable use terms before access is granted
BYOD	Bring your own device: personal hardware accessing corporate resources
MDM	Mobile device management: enrolment and policy enforcement on a device
Hardening	Removing everything a device does not need
Secure baseline	One documented configuration standard per device type
Configuration drift	An undocumented change that moves a device away from its baseline
Minimal functionality	A device does only the job it was bought for
NAC	Network access control: posture checking before a device joins
Posture assessment	Checks antivirus, patches, settings and user credentials
Quarantine segment	A restricted segment for devices that fail posture checks
Remediation network	A limited network that lets a failing device patch itself
802.1X	Port based authentication at the switch, before traffic flows
Supplicant / authenticator	The device that asks, and the switch port that relays
RADIUS	Remote authentication dial in user service: central authentication server
Key lifecycle	Generate, distribute, store, rotate, revoke, destroy
Hardware security module	Physical device that performs crypto without exposing the key
Key vault	Software key store with access control, auditing and logging
Secure enclave	Isolated execution area inside the processor

Term	Definition
Key rotation	Scheduled key replacement, which limits the blast radius of a leak
ACL	Access control list: permit or deny by address, port or protocol, first match wins
URL filtering	Blocking whole categories of site, usually at a proxy or service
DNS filtering	Blocking the name lookup before a connection can be made
Content filtering	Scanning traffic for malicious content and blocking it
Deep packet inspection	Examining packet contents in real time
DLP	Data loss prevention: stopping sensitive data leaving the organisation
Web proxy	Intermediary that enforces policy, caches content and hides internal addresses
Trust zone	A boundary defining what trust may cross it: untrusted, semi-trusted, trusted
Screened subnet (DMZ)	Buffer zone hosting public facing services, separate from the interior
Defence in depth	Several layers of control, because no single control is foolproof
Zero trust	No implicit trust from location; verify identity and context per request
Tiered model	Core (transport), distribution (policy), access (endpoints)
Spine-leaf	Data-centre fabric where every leaf connects to every spine
Stateless firewall	Filters each packet alone, with no connection context
Stateful firewall	Tracks connections in a state table and allows established flows
NGFW	Next-generation firewall: application aware, with deep packet inspection
IDS / IPS	Detect and alert / detect and block inline
WAF	Web application firewall: protects web apps at layer 7
Site-to-site VPN	Tunnel connecting whole networks, often IPsec tunnel mode
SSL VPN	Browser-based or TLS remote access, with no client install
Split tunnel	Only some traffic traverses the tunnel
ZTNA	Per-request verification: no implicit network trust
SASE	ZTNA plus SD-WAN delivered as a service
PFS	Perfect forward secrecy: ephemeral keys keep past traffic secret
HSTS	Tells browsers to refuse plaintext connections for the domain

Core concepts

8E, Physical, deception and audit

Physical controls protect the rooms that hold the network: equipment rooms, wiring closets and data centres, with key, combination, electronic or biometric access. Around them sit cameras (with coverage, retention and blind spots), visitor management, access logs and guards. Physical access defeats every logical control, so it comes first. Deception technologies add honeypots (low or high interaction) and honeynets, which give intelligence and early warning, provided the decoy is isolated and the monitoring is lawful: consent, privacy and entrapment all apply. Audits test whether controls exist and whether they work; internal audit uses your own team, external third party assessment brings independence. Prepare with documentation, evidence, briefings and a mock audit, then remediate and verify. PCI DSS, GDPR and data locality set the compliance context, and logs, configurations and access records are the evidence.

8F, Segmentation and special environments

Segmentation divides one network into many. VLANs split a physical switch into logical networks, firewall zones decide what may cross, and micro-segmentation applies policy per workload, so a compromised web server cannot reach the database on the same segment. Benefits are containment, a smaller attack surface and compliance, and the plan starts from data sensitivity and trust level, never convenience. Special environments get their own treatment: IoT devices are cheap, rarely patched and shipped with default credentials; industrial IoT and operational technology drive physical processes where availability outranks confidentiality. The Purdue model places field devices at levels 0 and 1, process control at 2, site operations at 3 and enterprise systems at 4, with tightly controlled traffic between layers, and an air gap where intrusion risk must be near zero. Because these devices cannot be patched during a production run, the control shifts from hardening the device to containing the segment.

8G, Guests and personal devices

A guest network is its own VLAN, with no route inward, enforced by firewall rules and access control lists, a bandwidth cap, and a captive portal that presents acceptable use terms, records agreement and captures a name or address for the log. BYOD is the same problem with personal hardware you do not own: segment the devices, limit what they reach, enrol them in mobile device management to enforce policy, and use certificate based authentication so the network knows the device and can revoke it. Define what a compliant device looks like, make enrolment a condition of connecting, separate work data from personal data, and be ready to wipe corporate data from a lost device.

8B, Hardening and admission control

Hardening removes everything the device does not need: change default credentials immediately, disable unused services, close unused ports, disable unused protocols, and patch firmware and software promptly with automation. Build a secure configuration baseline from published guides (CIS benchmarks, NIST publications and vendor hardening guides), one standard per device type, then audit against it to catch configuration drift. The principle is minimal functionality: a router routes and does not host a website. Admission control then decides who joins. NAC performs posture assessment (antivirus presence and currency, operating system patches, configuration settings and user credentials) with outcomes of allow, quarantine into a restricted segment, or deny, plus a remediation network so a device can fix itself. The

mechanism is 802.1X port based authentication: the device is the supplicant, the switch is the authenticator, and a RADIUS server makes the decision. Deploy in phases, in monitor mode first, because false positives lock out healthy devices.

8H, Key management and content control

A key has a lifecycle: generation from a secure random source seeded with real entropy, distribution without exposure, storage, rotation on a schedule, revocation, and destruction including backups. Keys live in a hardware security module (physical, never exposes the key), a key vault (software, with access control and auditing), a secure enclave (inside the processor), or under a key management system that centralises the lifecycle. Rotation limits the blast radius of a leak. Filtering turns policy into enforcement: an access control list permits or denies by source, destination, port or protocol, is evaluated in sequence, and stops at the first match, so a permit everything rule at the top makes the rest decoration. URL filtering blocks whole categories, DNS filtering blocks the lookup, content filtering blocks malicious content, deep packet inspection examines contents in real time, data loss prevention stops sensitive data leaving, and a web proxy enforces policy, caches and hides internal addresses.

8A, Trust zones and the retained exam objectives

Trust zones describe architecture: the untrusted internet, the trusted interior, semi-trusted partner, branch and guest networks, and the screened subnet (DMZ) that buffers public facing services. Zone based policy governs every path between zones, deliberately asymmetric so the DMZ cannot initiate back into the interior, layered with defence in depth, and validated per request under zero trust. Architecture models: tiered (core, distribution, access), spine-leaf for low-latency data-centre fabrics, and flat SMB designs, with redundancy to remove single points of failure. Appliances: stateless and stateful firewalls, NGFW and UTM, IDS versus IPS, proxy, WAF and load balancer. Remote access: site-to-site, remote access and SSL VPNs, split tunnel, and ZTNA with SASE, with MFA non-negotiable on RDP. Protocols: TLS 1.2 and 1.3 current, PFS, certificate validation, and the toolkit of TLS/HTTPS, SSH/SFTP, IPsec, S/MIME, DNSSEC and HSTS.

Practical cautions

- Do not deploy a decoy without consent, and never let it solicit an attack: that is entrapment.
- Do not let a honeypot reach production: isolation is mandatory, or you have built an attacker a stepping stone.
- Do not treat IoT or industrial devices as ordinary endpoints: they are untrusted by default and often unpatchable.
- Do not plan segmentation from convenience: plan it from data sensitivity and trust level.
- Do not put guests on an internal segment, and do not rely on a Wi-Fi password as the control.
- Do not approve BYOD without enrolment, a certificate and a selective wipe capability.
- Do not skip default credentials: they are published, and every attacker already has them.
- Do not write a baseline from memory, and do not leave it unaudited: drift is the enemy.
- Do not enforce NAC without a pilot and monitor mode: false positives lock out healthy devices.
- Do not forget that ACL order matters: first match wins, so a permit everything rule at the top defeats the list.

- Do not confuse IDS (detects and alerts) with IPS (blocks inline).
- Do not expect signature detection to find new attacks; anomaly detection covers the unknown.
- Do not call TLS 1.0 acceptable: SSL and TLS 1.0 / 1.1 are deprecated.
- Do not assume a split tunnel protects all user traffic: it only covers the tunnel.
- Do not put public services inside the internal segment: that is the screened subnet's job.
- Do not forget MFA on remote access: it is the non-negotiable control.
- Do not treat a firewall's state tracking as encryption: filtering and encryption are separate.

Self-check questions

Answers are in your session slides

If you cannot answer a self-check from memory, revisit the corresponding slide, then retake the quiz.

Exam tips for Session 8

- Scenario questions ask which control fits: classify by what the control does, when it acts and where it sits.
- Segmentation and containment questions are answered by what limits lateral movement.
- Industrial and IoT scenarios usually want isolation plus monitoring, not patching.
- Guest and BYOD scenarios want a separate segment, a portal or enrolment, and no internal trust.
- Hardening questions want removal of unused services, credentials and a verified baseline.
- NAC questions want posture checking, with quarantine and remediation as the recovery path.
- Key management questions want rotation, storage and destruction, in that order of emphasis.
- ACL questions hinge on order and first match.
- IDS versus IPS and stateful versus stateless are the highest-frequency appliance distinctions.
- Know the VPN flavours, including IPsec tunnel mode, and the secure protocol toolkit (TLS, SSH, IPsec, S/MIME, DNSSEC).
- Read every quiz explanation: the distractors teach as much as the answers.

Further reading

- CompTIA Security+ SY0-701 Exam Objectives, Domain 3 (Security Architecture).
- Definitive CompTIA Network+ Certification Path, physical security, deception, segmentation, hardening, NAC, key management, filtering and network zones.
- NIST SP 800-41, guidelines on firewalls and firewall policy.
- NIST SP 800-53, security and privacy controls, including boundary protection and physical protection.
- Centre for Internet Security Benchmarks, published secure configuration baselines.
- IEEE 802.1X, port based network access control.
- PCI DSS and the UK GDPR, the regulatory regimes discussed in this session.

- RFC 8446, TLS 1.3; RFC 6071, the IPsec and IKE documentation roadmap.